

UAT-10147 IIS DEFENDER EXCLUSION COMMANDS

Source-observed PowerShell and Registry commands adding standard IIS directories to Microsoft Defender exclusions.

HUNTING QUERY

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

DeviceProcessEvents

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

21 August 2026

VERSION

v1.0

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceProcessEvents

ATT&CK

T1685

Evidence-led dossier. Query status remains an untested
implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER



EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Hunt the complete source-observed exclusion commands.

Cisco Talos observed UAT-10147 using EfsPotato to launch PowerShell and Registry commands that add the standard IIS inet_srv directories to Microsoft Defender exclusions. Defender process telemetry exposes the executable, full command line, account, device and parent context.

OPERATIONAL VALUE

A post-exploitation defense-impairment pivot before later payloads.

The combination of a Defender-exclusion operation and a standard IIS directory is materially more selective than PowerShell, reg.exe or an exclusion command alone. It can expose an attempt even when Tamper Protection blocks the configuration change.

9.2

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Hunting

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

Observed behavior

- Talos published the Windows post-compromise chain on 20 August 2026.
- EfsPotato launched Add-MpPreference for the System32 and SysWOW64 IIS inet_srv directories.
- The actor also used reg add against Microsoft\Windows Defender\Exclusions\Paths for the same directories.
- The chain later downloaded BadIIS, but the query does not infer that stage occurred.

ANALYTICAL ASSESSMENT

What the evidence supports

- Both command variants express the same source-observed defense-impairment behavior.
- The IIS directory predicate materially narrows common administrative overlap.
- A matching process is an investigation lead, not proof that the exclusion succeeded or that UAT-10147 was responsible.

DETECTION ASSUMPTIONS

What must be validated

- Microsoft Defender for Endpoint process events are retained for the affected Windows server.
- ProcessCommandLine is complete enough to preserve the cmdlet, Registry path and target directory.
- The operation follows one of the two source-observed command mechanisms.

Confidence boundary

The query does not observe Microsoft Defender configuration state, command success, exploitation, EfsPotato execution, BadIIS installation or actor attribution. Other APIs, the Defender UI, renamed tooling and changed target paths are outside coverage.



THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

ATTACK FLOW

01

Web-server access

The actor obtains code execution on a Windows web server.

02

Privilege escalation

EfsPotato is used to launch privileged commands.

03

Exclusion command

PowerShell or reg.exe targets a Defender exclusion path.

04

IIS directory

System32 or SysWOW64 inetsrv is named as the exclusion.

05

Later staging

The source reports subsequent BadIIS delivery and IIS discovery.

Observable core

A PowerShell process containing Add-MpPreference and -ExclusionPath, or reg.exe adding a Windows Defender Exclusions Paths value, with either standard IIS inetsrv directory in the same command line.

Non-observable boundary

Command return code, current exclusion state, Tamper Protection outcome, payload contents, successful BadIIS loading, C2 activity and attribution.

DETECTION HYPOTHESIS

The source-observed Defender exclusion should remain visible in process telemetry.

If an attacker repeats the documented defense-impairment step, DeviceProcessEvents should show PowerShell or reg.exe adding a Microsoft Defender exclusion for a standard IIS inetsrv directory. Change authorization, server role, process lineage and resulting Defender configuration distinguish legitimate administration from compromise.

REQUIRED TELEMETRY

DeviceProcessEvents

- Microsoft Defender for Endpoint process creation telemetry.
- FileName and complete ProcessCommandLine.
- Device identity and event identifiers.

OPTIONAL ENRICHMENT

Context that improves disposition

- Account, integrity and token-elevation context.
- Parent process and remote-session context.
- Defender configuration state, file and network activity.

UNAVAILABLE HERE

Do not infer

- Command exit status in DeviceProcessEvents.
- Defender configuration state from this event alone.
- Payload content, C2 success and actor attribution.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Defender XDR · DeviceProcessEvents

DeviceProcessEvents records process creation and related events with executable name, full command line, device, account, integrity, parent-process and stable process identifiers.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

A match establishes that the source-aligned command was observed. It does not establish that Microsoft Defender accepted the exclusion or that later malware stages executed.

REQUIRED AND ENRICHMENT FIELD MODEL

CATEGORY	FIELD	PURPOSE	REQUIREMENT
Process event	DeviceProcessEvents	Native MDE process telemetry.	REQUIRED
Executable	FileName	Separates PowerShell from Registry command paths.	REQUIRED
Command	ProcessCommandLine	All evidence-bearing predicates.	REQUIRED
Device	DeviceId, DeviceName	Server investigation pivot.	REQUIRED
Event	Timestamp, ReportId	Event identity and ordering.	REQUIRED
Account	AccountDomain, AccountName	Authorization review.	OPTIONAL
Process context	ProcessIntegrityLevel, ProcessTokenElevation, ProcessUniqueId	Privilege and correlation enrichment.	OPTIONAL
Parent	InitiatingProcessFileName, InitiatingProcessCommandLi ne	Origin and lineage.	OPTIONAL

Data quality requirements

- Confirm process coverage on Windows IIS servers.
- Measure command-line completeness and truncation.
- Verify DeviceId and ReportId population.
- Retain raw events for analyst review.

Known failure conditions

- MDE is absent or the server is not onboarded.
- The command line is truncated before the evidence-bearing strings.
- The exclusion is created through an API, UI or different tool.
- The actor changes the target path or suppresses process telemetry.



DETECTION LOGIC

Primary-platform logic with every condition traceable to evidence.

HUNTING QUERY

DETECTION OBJECTIVE

Find the documented IIS Defender-exclusion command variants.

Select only the two source-observed command mechanisms when either standard IIS inetsrv directory is present in the same command line.

ANALYTICAL LOGIC

Direct filters and investigable output.

Direct executable and command-line filters only. No join, aggregation, rarity, score, broad encoded-command predicate or arbitrary threshold.

KQL · UNTESTED HUNT

```
// Hunting query - Untested implementation sketch
// Primary platform: Microsoft Defender XDR / Advanced Hunting
// Required telemetry: Microsoft Defender for Endpoint process creation events on Windows
// Evidence: Cisco Talos observed UAT-10147 adding the two standard IIS inetsrv
// directories to Microsoft Defender exclusions with Add-MpPreference and reg.exe.
DeviceProcessEvents
| where
(
  FileName in~ ("powershell.exe", "powershell_ise.exe", "pwsh.exe")
  and ProcessCommandLine contains "Add-MpPreference"
  and ProcessCommandLine contains "-ExclusionPath"
)
or
(
  FileName =~ "reg.exe"
  and ProcessCommandLine contains "reg add"
  and ProcessCommandLine contains @"Windows Defender\Exclusions\Paths"
)
| where
  ProcessCommandLine contains @"C:\Windows\System32\inetsrv"
  or ProcessCommandLine contains @"C:\Windows\SysWOW64\inetsrv"
| extend ExclusionMethod = iff(FileName =~ "reg.exe", "Registry command", "PowerShell cmdlet")
| project
  Timestamp, DeviceId, DeviceName, ReportId,
  AccountDomain, AccountName, AccountSid,
  FileName, FolderPath, SHA1, ProcessCommandLine,
  ProcessIntegrityLevel, ProcessTokenElevation, ProcessUniqueId,
  InitiatingProcessFileName, InitiatingProcessFolderPath,
  InitiatingProcessCommandLine, InitiatingProcessSHA1,
  InitiatingProcessAccountDomain, InitiatingProcessAccountName,
  IsProcessRemoteSession, ProcessRemoteSessionIP,
  ExclusionMethod
| order by Timestamp desc
```

STATUS	THRESHOLD	JOIN / SEQUENCE	PRIMARY KEY	DISPOSITION
Untested hunt	None	None	DeviceId + ProcessUniqueId	Manual triage

What a match means

A source-aligned attempt to add a standard IIS directory to Microsoft Defender exclusions occurred and requires authorization and state validation.

What a match does not prove

Successful configuration change, exploitation, privilege escalation, BadIIS deployment, C2 activity or UAT-10147 attribution.



TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm the raw process event.
Preserve the complete command, process key, account, device and parent context.
- 02

Validate authorization.
Check change tickets, deployment tools, performance exceptions and approved administration.
- 03

Confirm the server role.
Establish whether IIS is installed and why an inetsrv exclusion would be required.
- 04

Check Defender state.
Determine whether the exclusion exists, when it changed and whether Tamper Protection blocked the attempt.
- 05

Review adjacent activity.
Inspect EfsPotato, appcmd, archive extraction, BadIIS files, new users and network follow-on.

Escalation gate

Escalate when the command is unauthorized, appears on an internet-facing IIS server, runs from a suspicious parent or privileged remote session, changes Defender state, or is followed by source-aligned IIS module, account or network activity.

Primary benign overlap

Administrators, performance troubleshooting, installers and approved security tests can create Defender exclusions. Tune only with verified change records, approved account and process lineage, host role and resulting configuration state; never allowlist PowerShell or reg.exe globally.

INVESTIGATION PIVOTS

Host
IIS role, exposure, ownership and MDE health.

Account
Privilege, logon session and change authorization.

Process
Parent, children, integrity, token elevation and remote session.

Defender
Exclusion state, configuration history and Tamper Protection.

Files
EfsPotato, archives, DLLs and IIS module provenance.

Network
Web-shell access and post-command destinations.

DISPOSITION CRITERIA

OUTCOME	MINIMUM EVIDENCE	ACTION
BENIGN	Approved, owned and repeatable activity.	Document and tune narrowly.
SUSPICIOUS	Unknown activity without corroborated malicious follow-on.	Deepen endpoint review.
LIKELY MALICIOUS	Unauthorized match plus coherent file, process, network or control-plane evidence.	Escalate incident response.



FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	WHY IT OVERLAPS	TUNING ACTION
Approved IIS performance exception	An administrator may exclude a web-server directory.	Require owned change record, named operator and verified resulting configuration.
Deployment or packaging script	Enterprise automation may configure exclusions during installation.	Validate signed package, known parent process and deployment window.
Security validation	A controlled test may reproduce the exact command.	Restrict tuning to approved lab hosts, operators and test windows.

Baseline plan

- Run across available process-event retention for IIS servers.
- Review every complete match with system owners.
- Measure command-line and parent-field completeness.
- Do not introduce a count or rarity threshold.

Validation procedure

- Replay both positive commands in an isolated MDE-onboarded Windows lab.
- Verify Tamper Protection-blocked attempts remain visible.
- Execute both negative controls.
- Compare historical results with approved Defender exclusion inventory.

TEST CASES

CASE	EXPECTED RESULT
PowerShell Add-MpPreference for System32 inetsrv	Expected match with PowerShell method.
reg add for SysWOW64 inetsrv	Expected match with Registry method.
Add-MpPreference for an unrelated approved path	No match.
Command mentions inetsrv without Defender-exclusion operation	No match.

Hunting

Initial query

Candidate

Current status

Production

Measured precision

Optimized

Stable feedback

Success

Both controlled positive commands match, negative controls do not, evidence-bearing command lines are complete and historical matches are absent or attributable to approved change.

Rejection

Legitimate operations frequently reproduce the complete command and target paths without a durable authorization or provenance discriminator.

Failure

Process telemetry is absent, evidence strings are truncated or controlled commands produce no usable DeviceProcessEvents record.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	COVERAGE STATEMENT
T1685	Disable or Modify Tools	Directly covers source-observed commands that modify Microsoft Defender exclusions to reduce security-tool visibility for standard IIS directories.

Detection coverage summary

Strong for the two documented command mechanisms and paths; weak for API or UI changes, renamed tools, different exclusions, command-line loss and unmonitored servers.

Residual risk

The actor can use alternate Defender configuration interfaces, disable other controls, change paths or evade endpoint telemetry. Configuration-state monitoring and complementary file, module and network detections remain necessary.

ANALYST CONCLUSION

A high-value post-exploitation hunt with explicit success boundaries.

Talos provides the exact PowerShell, Registry and IIS path combinations, while Microsoft documents every primary query field. The behavior is directly observable and selective, but environmental overlap and the inability to prove configuration success keep it at Medium-confidence Hunting status.

REFERENCES

- Cisco Talos, "UAT-10147: Chinese-speaking adversary integrates agentic AI into post-compromise operations," 20 August 2026. <https://blog.talosintelligence.com/uat-10147-chinese-speaking-adversary-integrates-agentic-ai-into-post-compromise-operations/>
- Cisco Talos, "UAT-10147 deploys SPECTRE, a cross-platform implant with Linux rootkit and BYOVD capabilities," 20 August 2026. <https://blog.talosintelligence.com/uat-10147-deploys-spectre-a-cross-platform-implant-with-linux-rootkit-and-byovd-capabilities/>
- Microsoft Learn, "DeviceProcessEvents table in the advanced hunting schema," updated 7 August 2026; accessed 21 August 2026. <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>
- MITRE ATT&CK, T1685, Disable or Modify Tools; accessed 21 August 2026. <https://attack.mitre.org/techniques/T1685/>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0	21 August 2026	Hunting	Detection Engineering

Publication control

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.